



CISA VULNERABILITY SCANNING (VS)

Frequently Asked Questions

This report format looks different than before. What has changed and why?

Yes! We did make changes based on customer feedback. The updated report structure is designed to be more concise, actionable, and aligned with what customers told us they need. Key improvements include:

- Shorter report: Removed redundant sections and streamlined content for easier navigation.
- Graphics update: Removed graphics deemed non-essential or overly complex and added new visuals to highlight trends customers requested.
- Enhanced methodology details: Included clearer explanations of how findings are identified and scored, giving you better insight into the service and its processes.
- Improved usability: Added tailored graphics for different organization types to make reports more practical and informative.
- Keep what works: Continue providing all ingestible attachments as we understand customers find this particular section to be significantly useful/impactful.

These changes aim to provide the best possible overview of the service, its findings, and actionable insights—while reducing unnecessary clutter.

I think the vulnerability listed in my report is a false positive. Can you remove it from my report?

If you believe the finding to be in error, please complete and return the False Positive Assertion Form found in the Attachments page of your report. By default, false positive marking expirations are set for a period of 1 year since many changes generally occur within that period (e.g. patches and updates) and the vulnerability might be naturally remediated through that change.

CISA will review and perform our own analysis. This will not include exploiting the vulnerability but may include actively sending packets to the host in question. When false positive assertions are accepted by CISA, that acceptance should not be construed as validation that a finding is in fact a false positive. CISA reserves the right to assert that certain findings are not false positives.

Can I get the data you created this report from in CSV?

Certainly! See the Attachments page.

Why is my report not showing any hosts and not returning results?

It looks like none of the IPs in your scope were detected as hosts with at least one open port/listening service, so we couldn't communicate with any IPs to check for vulnerabilities. Typically, the reason we don't find any hosts is because we are getting blocked by something. Our goal is to evaluate your network from the

perspective of an attacker (we don't exploit the vulnerabilities, just detect and report them to you). For this reason, we don't want to be provided with preferential treatment or atypical network access. Please check your firewall configuration for any blocked traffic from our scanners (<https://rules.vm.cyber.dhs.gov/cyhy.txt>) and why it may be dropping the traffic. Once you make changes, let us know so we can jumpstart the scanning (otherwise it could be as many as 90 days until the rescans occur again on their own based on the non-host status of your IPs).

Why do the host counts in my Cyber Hygiene report not match the number of known Internet-facing end points on my network?

This is likely due to a difference in what we're defining as a host. CyHy considers a device a host if there is at least one open port/service operating at the address. When we scan, any number of things can occur that make it appear that nothing is at that address (e.g., our scans are blocked by host or network filters, the device is down for maintenance, packets are dropped or lost en route, etc.).

The intent of CyHy is to find vulnerabilities, not count hosts, and our metrics should not be relied upon as a verified host count of your organization.

I have a new host within our scope. Why aren't your scans picking it up?

CyHy is not scanning your entire IP scope every week. If you've stood up a new server in a range that we only recently scanned and found nothing in, it's possible that the new server will not appear for nearly 90 days. If you want the new host to be scanned immediately, you can email vulnerability@cisa.dhs.gov and we'll manually scan it, which will add it to your weekly report.

How can I change who receives my Cyber Hygiene report?

CISA strongly recommends using a distribution address for your report, allowing the CyHy VS report to be delivered to a single email address. This allows your organization to grant access to the report to whomever you'd like, as well as manage the change control of employees onboarding or leaving. If you need to change the distro we mail to, email us at vulnerability@cisa.dhs.gov.

Can I change the password for my report?

If you need to request a new password for your report, email us at vulnerability@cisa.dhs.gov.

Why am I getting SSL/TLS certificate vulnerabilities that I think are incorrect?

In our scans, we will use the Mozilla trust store. CISA will not accept any other roots. This is done as a matter of practice and principle: as practice, because maintaining private roots from our various stakeholders is operationally infeasible; as principle, because our scans aim to ensure that the user of your services is protected. The Mozilla trust store is generally representative of a 'lowest common denominator' in what a public-serving site can reasonably expect of those users whose devices they do not manage.

Ensure that the root your certificate is issued from is included in the Mozilla root store. You should also verify that the intermediate certificates are presented with your site certificate. This allows the scanner to validate the certificate's chain of trust.

Though the site is Federal Government-centric, tons of great information can be found at <https://cio.gov> regarding Hypertext Transfer Protocol Secure (HTTPS), much of which is applicable for SSL/TLS more generally.

Why is one of the Operating Systems reported incorrect?

OS identification is a function of Nmap, one of the tools we use in scanning. An attempt is made to detect the operating system by evaluating how a system responds compared to known responders. If Nmap is wrong and you'd be willing to help the security ecosystem, we'd encourage you to check out <https://nmap.org/book/osdetect-unidentified.html> where instructions are given how to collect an OS fingerprint and then submit them to the tool's development team. We'd love to hear back from you if you have success doing this! Your contributions to the tool will get incorporated into Nmap, and we generally stay current with the latest versions.

I fixed a vulnerability listed in my report. Can you rescan to verify?

CyHy automatically rescans whenever a vulnerability is detected, so there is no need to notify us that you've fixed something. If we can no longer detect the vulnerability, it will be listed in the Attachments Appendix.

How do you know if the vulnerability has truly been mitigated? We have IPs that are shown as mitigated one week and then the next week re-detected, then the next week, mitigated, etc.

If a vulnerability is disappearing and reappearing on your Cyber Hygiene Reports, it could be what we like to call a "flapper" (due to false negative responses). As is the nature of Internet scanning, we have no ability to tell whether a vulnerability which we detect at one point but not at another is actually remediated, though we hope that is the case. Our scans could be blocked by a host firewall, not received because a system was brought down for maintenance, dropped by your ISP, caught in a fancy UTM box, or you could have fixed the issue.

Why are there recurring vulnerabilities?

After you've remediated a vulnerability (and it remains resolved for a period of 90 days), the host's scan priority will drop. This approach allows CISA to focus on the areas of importance and give more attention to the hosts that need it.

Vulnerabilities are assigned an age in order to track timeliness of remediation. Vulnerability age is determined by when it was first detected on a host, not from when it first appeared on a report. As scanning occurs continuously between weekly reports, it is possible to have "new" vulnerabilities appear on a report that are already days old. It is also possible for a vulnerability to fluctuate between being detected and not detected during mid-week scans and then at a future time appear in a report as many days old.

If a mitigated vulnerability is re-detected less than 90 days after the date of non-detection, it will be considered to be the same vulnerability with the same "initial detection date" as previously recorded. If it is re-detected more than 90 days after the date of non-detection, it will be treated as a new vulnerability with a new "initial detection date".

Can you scan my domains or IPv6 addresses?

There is currently no ETA for CyHy to scan IPv6 addresses or domains, however, we are looking into adding these features in the future.